Proyecto 8: Seguridad en conexiones invisibles

Hardening TP-Link Archer C7

Autor: Carlos Alcina Romero

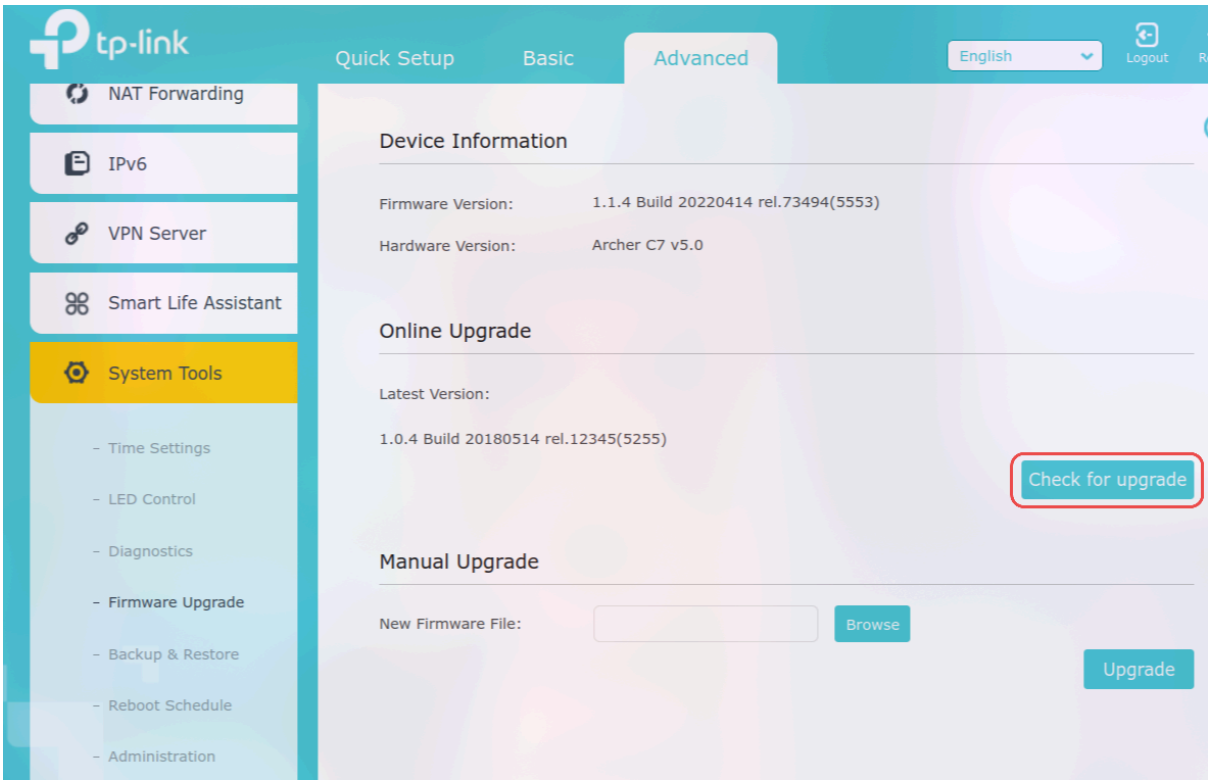
Introducción

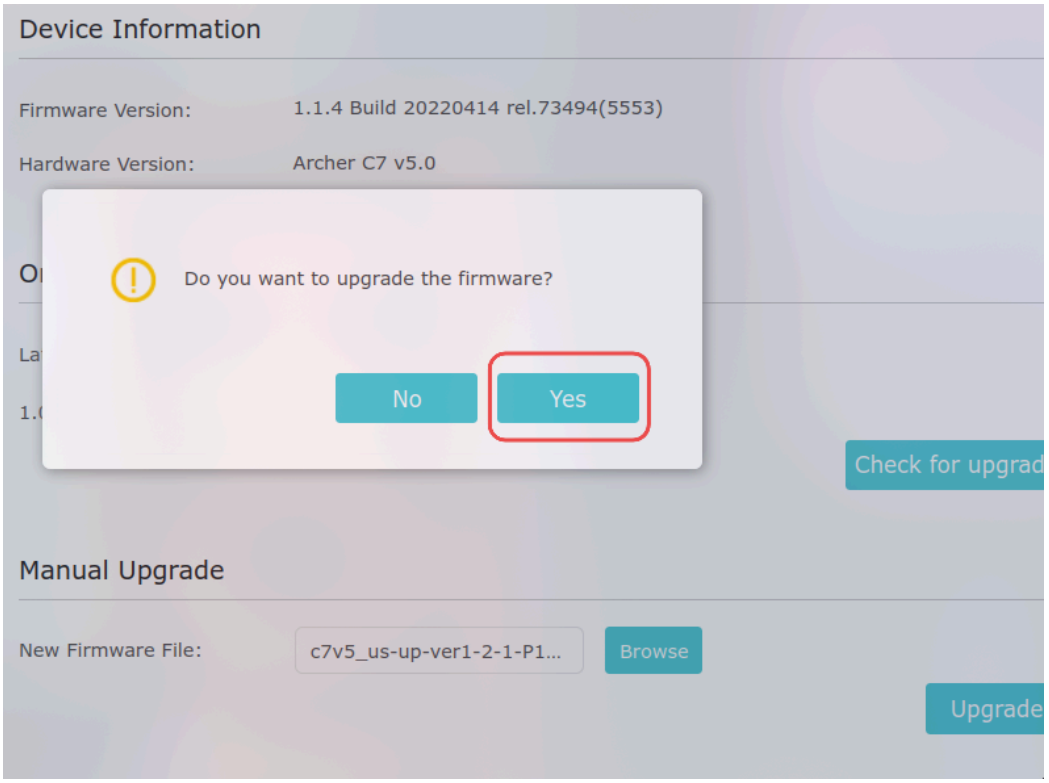
En el presente documento se detalla el proceso de bastionado (hardening) aplicado a un router doméstico TP-Link Archer C7. El objetivo es mitigar los riesgos de seguridad y las vulnerabilidades más comunes presentes en las configuraciones por defecto de este tipo de dispositivos, acercando su nivel de seguridad al de un entorno corporativo dentro de las limitaciones de su firmware.

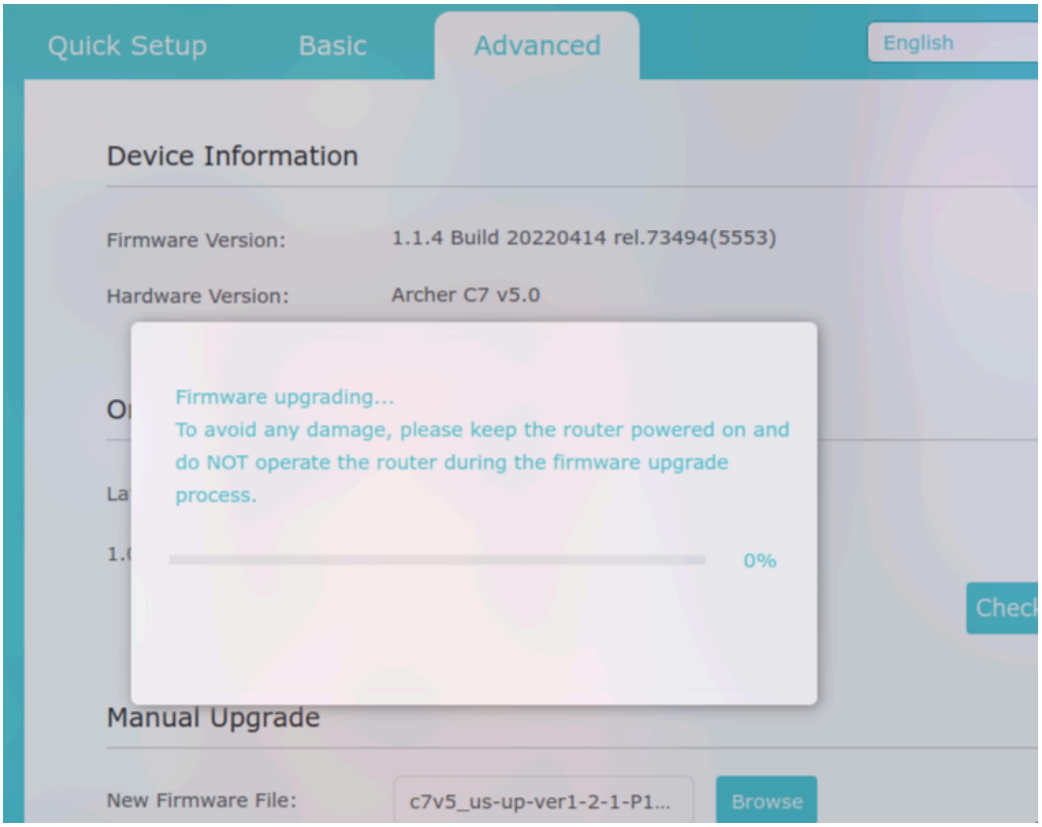
1. Actualización y Mantenimiento del Firmware

El primer paso en cualquier proceso de bastionado es asegurar que el dispositivo ejecuta la última versión del firmware proporcionada por el fabricante. Esto parchea vulnerabilidades conocidas (CVEs) que los atacantes podrían explotar.

Se ha accedido al apartado `System Tools` > `Firmware Upgrade` para verificar la versión actual y simular la actualización a la versión más reciente.




Device Information
Firmware Version: 1.1.4 Build 20220414 rel.73494(5553)
Hardware Version: Archer C7 v5.0
Do you want to upgrade the firmware?
No
Yes
Check for upgrad
Manual Upgrade
New Firmware File: c7v5_us-up-ver1-2-1-P1...
Browse
Upgrade

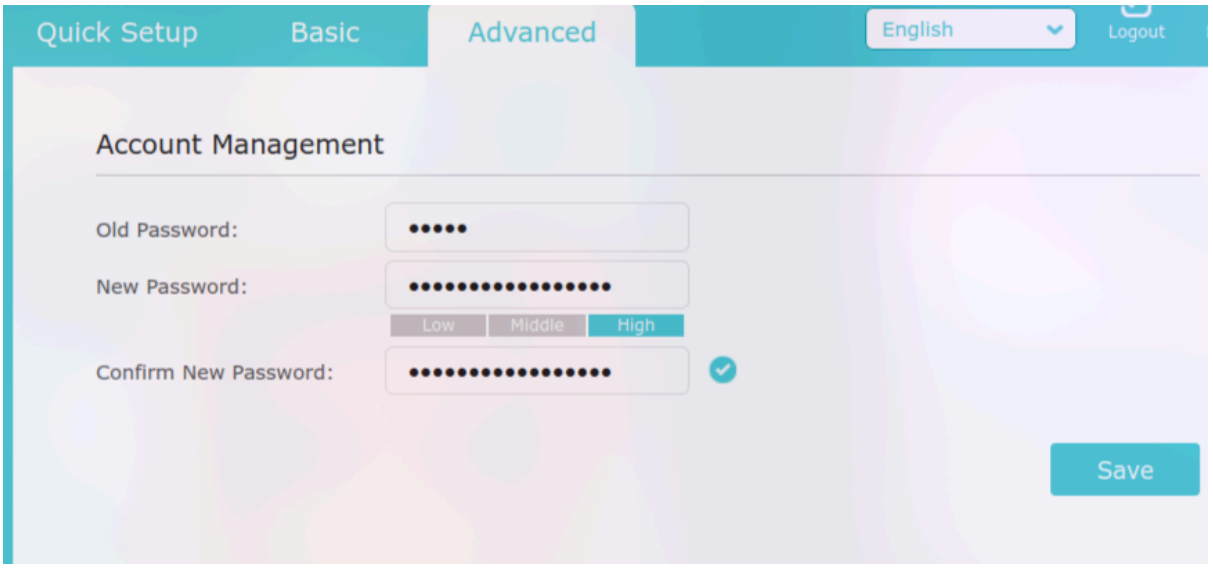

Quick Setup
Basic
Advanced
English
Device Information
Firmware Version: 1.1.4 Build 20220414 rel.73494(5553)
Hardware Version: Archer C7 v5.0
Firmware upgrading...
To avoid any damage, please keep the router powered on and do NOT operate the router during the firmware upgrade process.
0%
Manual Upgrade
New Firmware File: c7v5_us-up-ver1-2-1-P1...
Browse

2. Gestión de Credenciales y Acceso al Dispositivo

2.1. Cambio de la contraseña por defecto

Los routers traen credenciales conocidas públicamente (ej. admin/admin). Es crítico establecer una contraseña robusta (más de 12 caracteres, alfanumérica y símbolos) para evitar accesos no autorizados al panel de control.

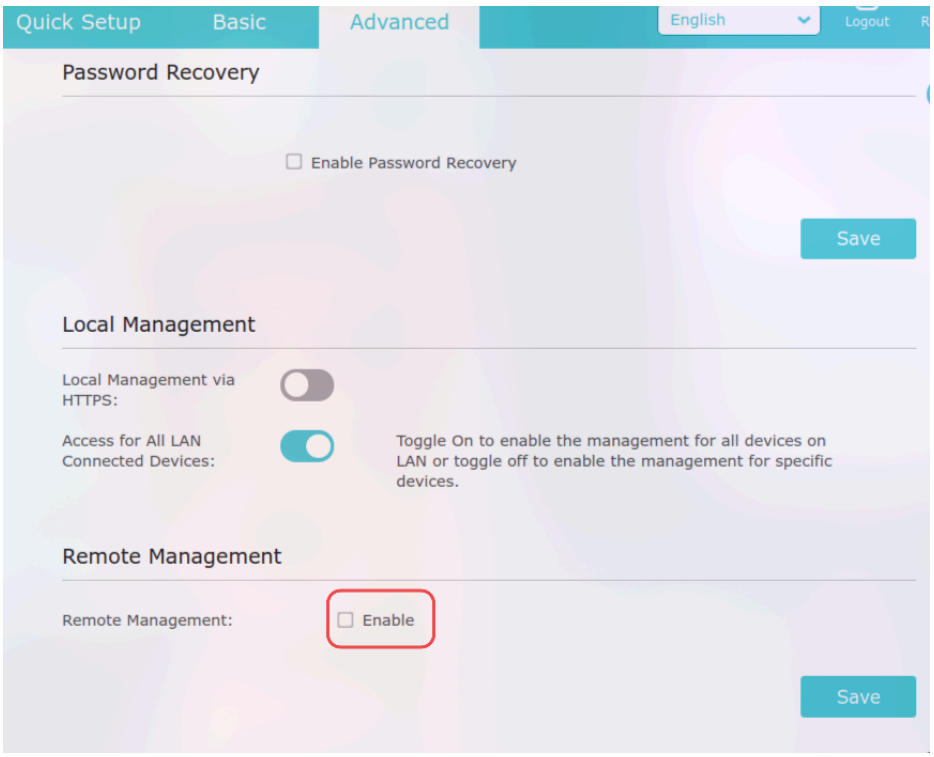
En `System Tools` > `Administration`, se ha modificado la contraseña predeterminada por una contraseña segura generada aleatoriamente.



2.2. Desactivación de la Gestión Remota (Remote Management)

Exponer el panel de administración a Internet (interfaz WAN) es un riesgo crítico. Solo debe administrarse el router desde la red local (LAN).

En `Security` > `Remote Management`, se ha verificado que la dirección IP de gestión remota esté en `0.0.0.0` o que la función esté deshabilitada (dependiendo de la versión del firmware), denegando el acceso desde el exterior.



2.3. Activado HTTPS acceso local

Como administrador, usar HTTP en un panel de administracion tan importante como es el router es un riesgo crítico. Usar HTTPS permite que la escucha de paquetes en la red local sea inútil.

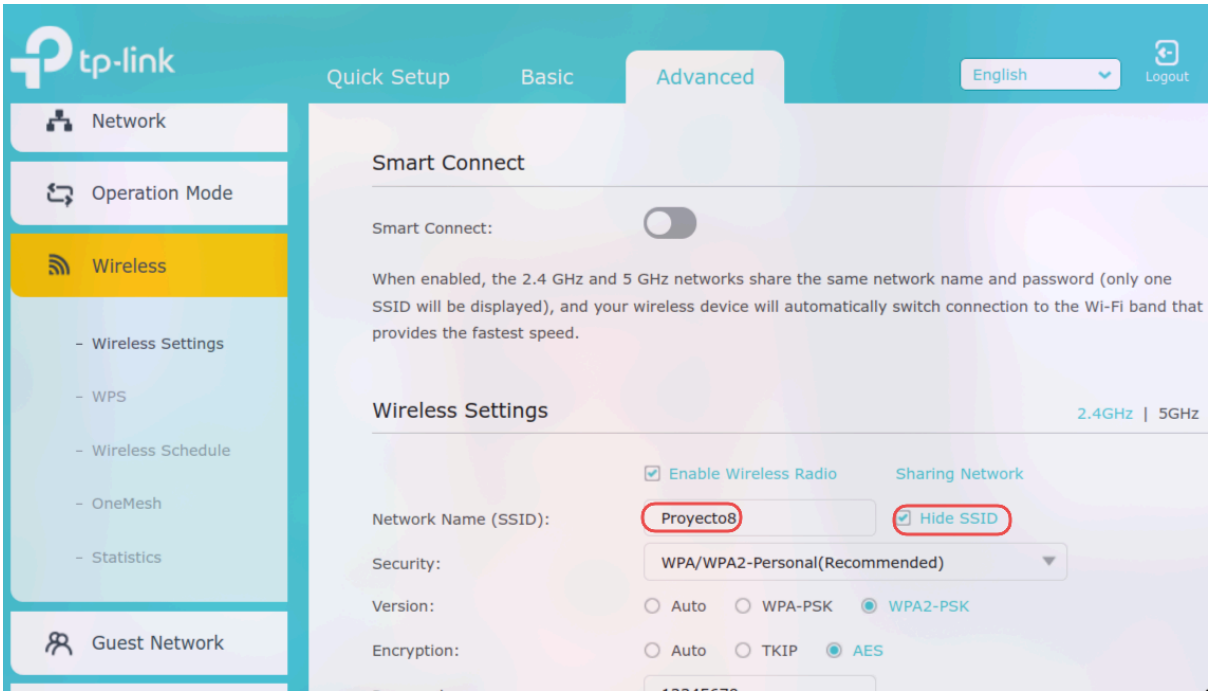
En `System Tools` > `Administration`, se ha habilitado el HTTPS en el panel de administración

3. Seguridad de la Red Inalámbrica (Wi-Fi)

3.1. Cambio de SSID y Ocultación

El nombre de red (SSID) por defecto suele revelar el modelo del router o el proveedor de Internet, dando pistas a un atacante sobre posibles vulnerabilidades. Ocultarlo no es una medida de seguridad definitiva, pero añade una capa de "seguridad por oscuridad".

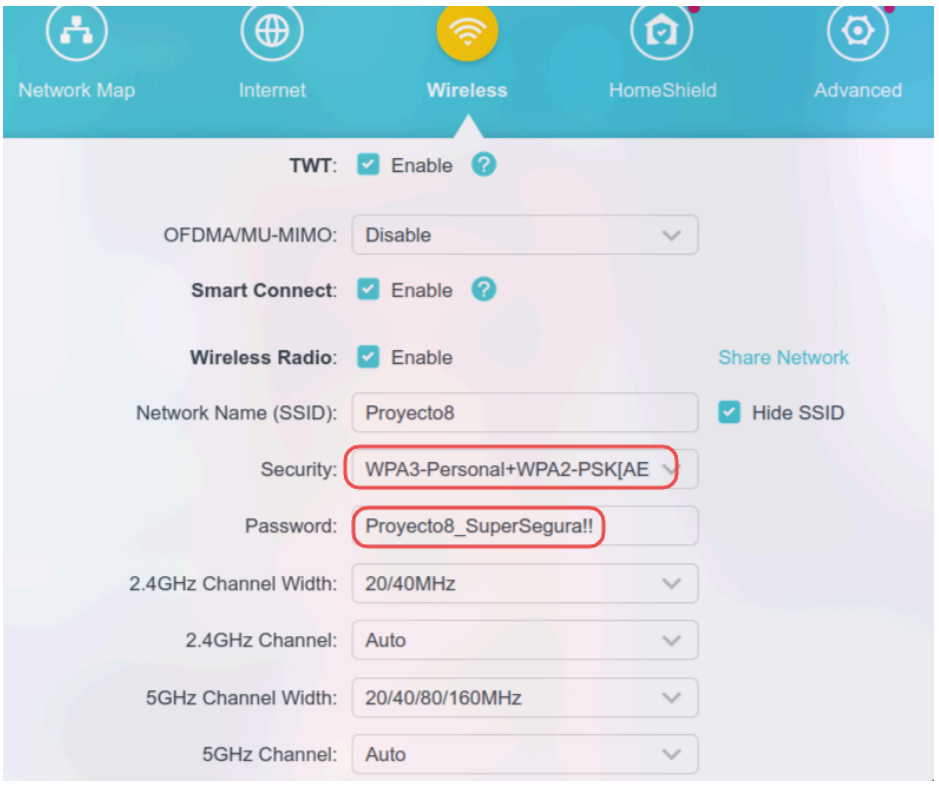
En `Wireless` > `Wireless Settings`, se ha modificado el SSID por defecto por un nombre genérico que no revela información y, opcionalmente, se ha desmarcado la casilla `Enable SSID Broadcast`.



3.2. Cifrado Fuerte (WPA2/WPA3 y AES)

Protocolos antiguos como WEP o WPA, y algoritmos como TKIP, son vulnerables y fácilmente crackeables. Se debe forzar el uso del estándar más alto disponible.

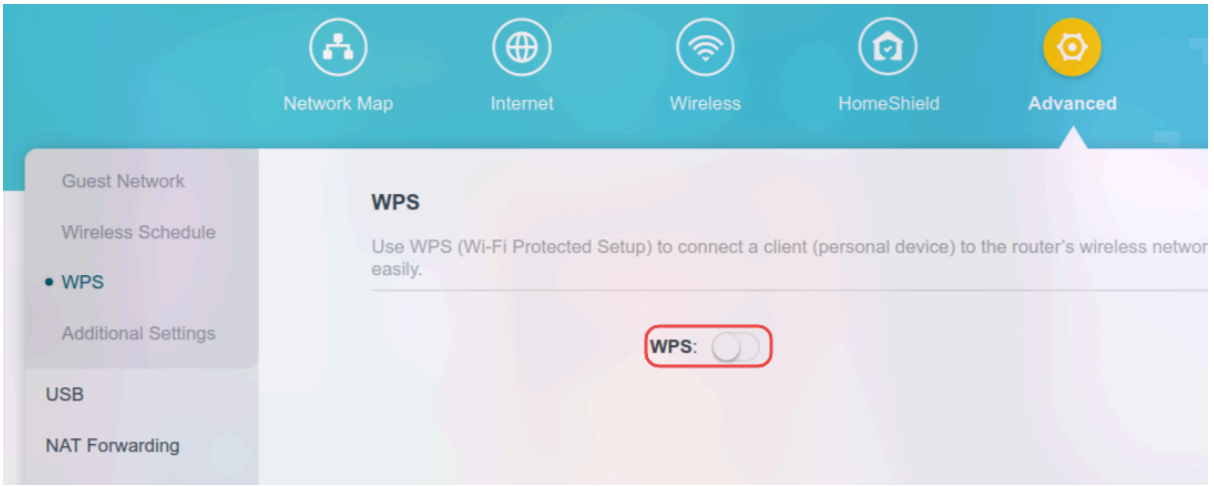
En `Wireless` > `Wireless Security`, se ha seleccionado **WPA3-Personal+WPA2-PSK[AES]** forzando la versión a **WPA3-Personal-WPA2-PSK** y la encriptación estrictamente a **AES**. Se ha establecido una contraseña Wi-Fi robusta.



3.3. Desactivación de WPS (Wi-Fi Protected Setup)

El WPS basado en PIN es altamente vulnerable a ataques de fuerza bruta (ataques tipo Reaver/Pixie Dust), permitiendo a un atacante obtener la contraseña WPA2 en horas. Debe estar siempre deshabilitado en entornos seguros.

En `Wireless` > `WPS`, se ha procedido a **deshabilitar** (Disable) la funcionalidad WPS del router.

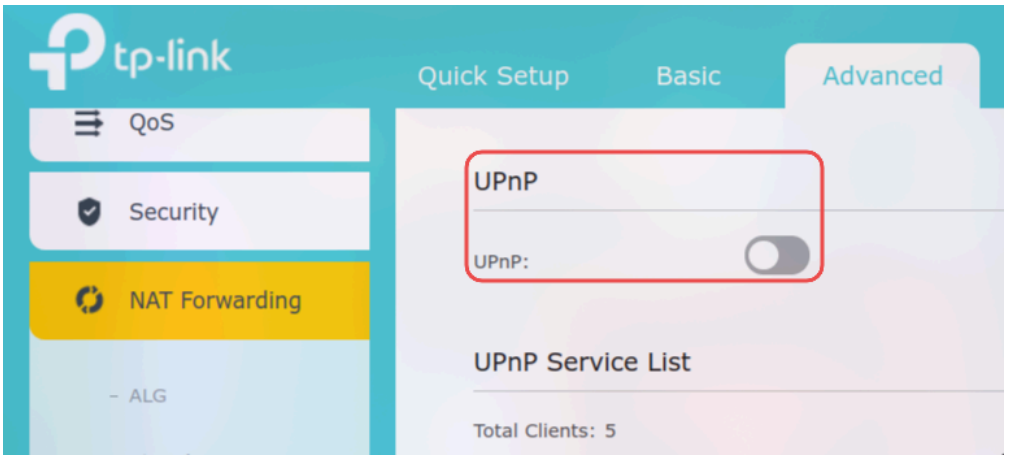


4. Fortificación de Servicios y Firewall

4.1. Desactivación de UPnP (Universal Plug and Play)

UPnP permite a los dispositivos de la red local abrir puertos en el router automáticamente. Si un equipo interno se infecta con malware, podría usar UPnP para abrir puertos y exponer servicios al exterior sin el conocimiento del administrador.

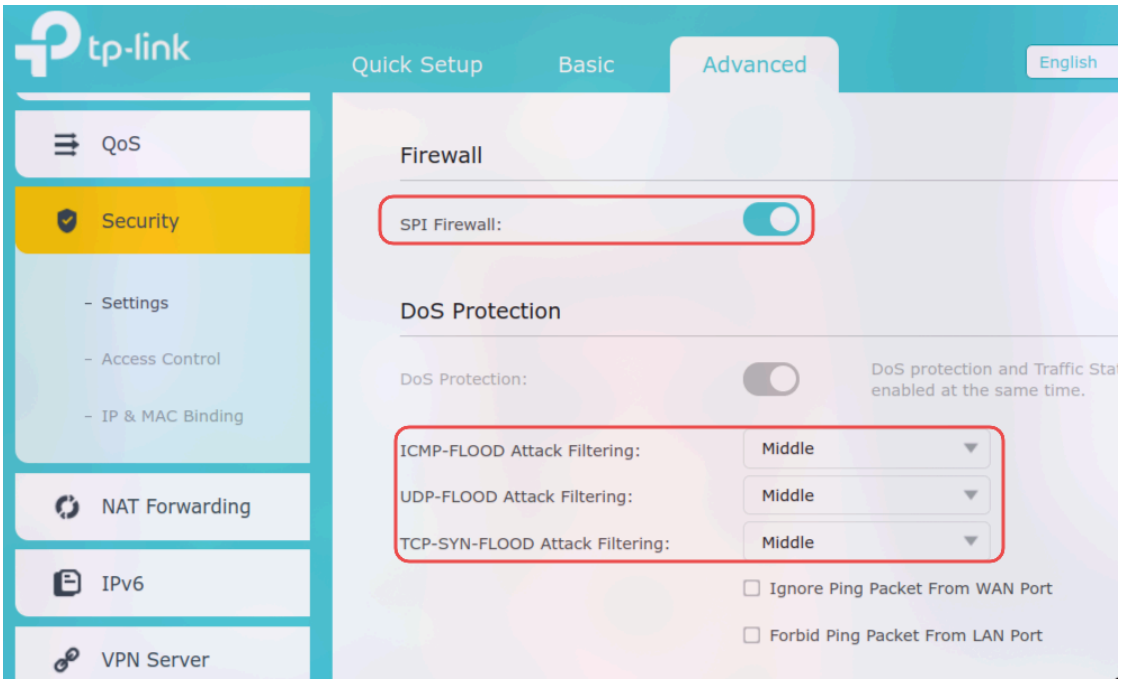
En `Forwarding` > UPnP, se ha cambiado el estado de "Enabled" (por defecto) a **Disabled**.



4.2. Comprobación del Firewall SPI y Protección DoS

El Firewall SPI (Stateful Packet Inspection) inspecciona los paquetes entrantes y evita conexiones no solicitadas. La protección DoS mitiga ataques de denegación de servicio básicos.

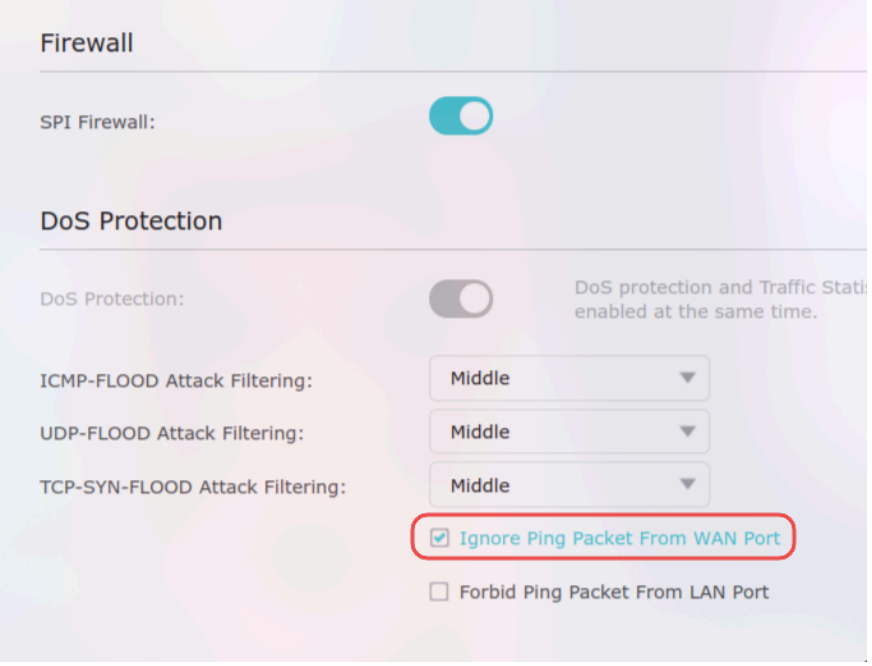
En `Security` > `Basic Security`, se ha confirmado que el **SPI Firewall está habilitado** (Enable). En `Security` > `Advanced Security`, se ha habilitado la prevención de ataques DoS y activado el filtrado de paquetes ICMP-FLOOD, UDP-FLOOD y TCP-SYN-FLOOD.



4.3. Bloqueo de Ping en la WAN (Ignore Ping from WAN)

Evitar que el router responda a paquetes ICMP (pings) desde Internet reduce la visibilidad del dispositivo ante escaneos automatizados en la red pública.

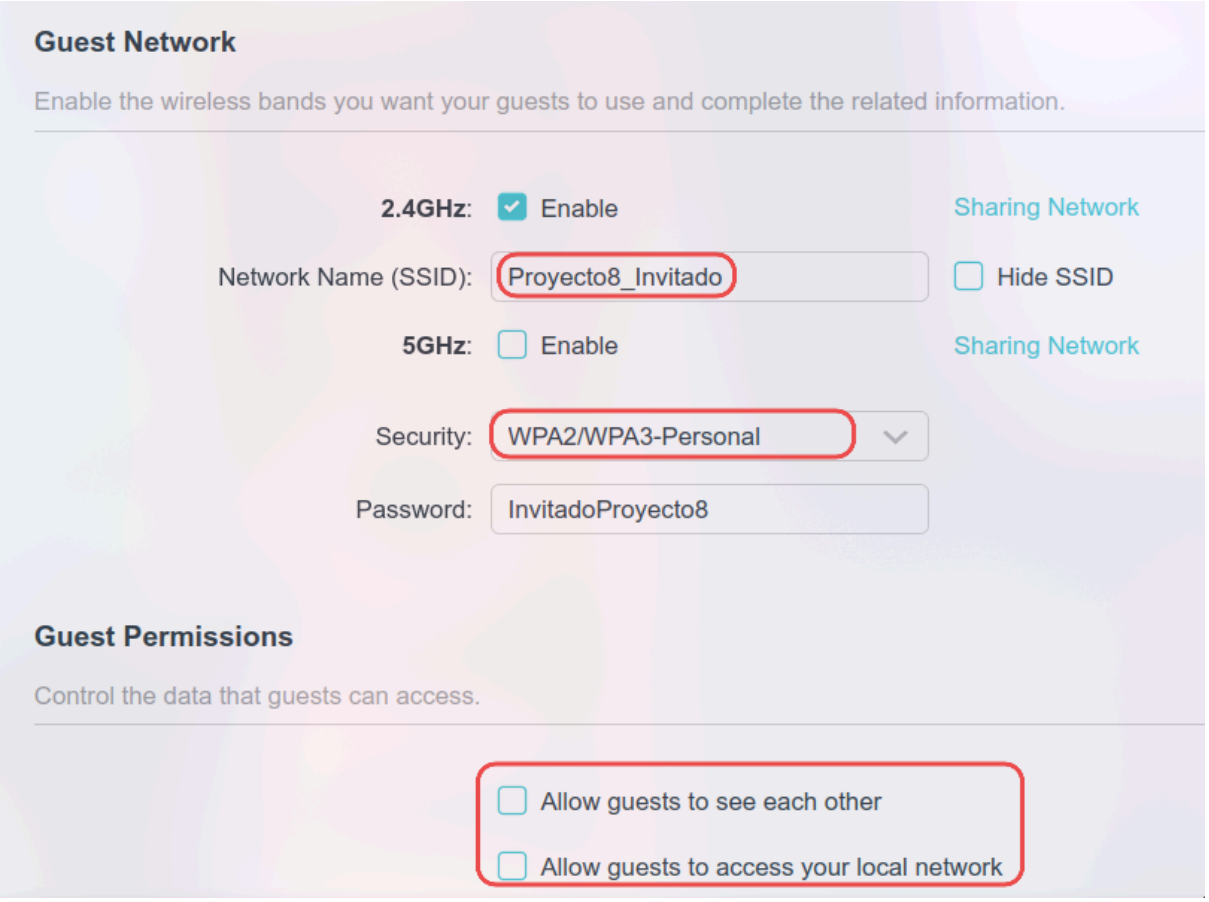
En `Security` > `Advanced Security`, se ha marcado la opción **Ignore Ping Packet From WAN Port**.



5. Segmentación: Red de Invitados (Guest Network)

Si se necesita dar acceso a terceros, nunca debe hacerse en la red principal (donde pueden estar conectados NAS, servidores o equipos de trabajo). Una red de invitados aísla a estos usuarios, permitiéndoles solo salir a Internet.

En `Guest Network`, se ha habilitado una red paralela. Es **crítico** asegurar que la opción *"Allow Guests to Access My Local Network"* esté **desmarcada** (Disabled) para garantizar el aislamiento, y aplicar a esta red el mismo nivel de cifrado WPA2/AES.



Conclusión

Aplicando estas medidas, la superficie de ataque del TP-Link Archer C7 se reduce drásticamente. Aunque no llega a disponer de las características avanzadas de un firewall corporativo (como IDS/IPS o inspección profunda de paquetes), se eliminan los vectores de entrada más comunes explotados en redes de pequeñas empresas y oficinas domésticas (SOHO), cumpliendo con los estándares mínimos de seguridad recomendados.